

nahsi IAM

Authentisierung und Autorisierung im Datenraum Gesundheit

Autor: Martin Smock

Projekt: DigiSanté Architektur

Ausgabe: 0.6

Datum: 4. Dezember 2024

Inhalt

1	EINFÜHRUNG UND ZIELE.....	3
1.1	AUFGABENSTELLUNG	3
1.2	ABGRENZUNG	3
1.3	QUALITÄTSZIELE	3
1.4	STAKEHOLDER.....	4
1.5	EXEMPLARISCHE ANWENDUNGSFÄLLE	4
1.5.1	Informationsaustausch im Behandlungskontext	4
1.5.2	Patientenapps im Behandlungskontext.....	6
1.5.3	Statistische Analyse	6
1.6	ABLÄUFE.....	7
1.6.1	Authentisierung von Benutzern	7
1.6.2	Autorisierung von Zugriffen	7
1.6.3	Durchsetzung der Zugriffsrechte	8
1.6.4	Consent Management	9
2	RANDBEDINGUNGEN	10
3	KONTEXTABGRENZUNG	11
3.1	FACHLICHER KONTEXT	11
3.2	TECHNISCHER KONTEXT	13
3.3	AUTHENTISIERUNG UND AUTORISIERUNG	13
3.4	CONSENT ENFORCEMENT.....	15
4	LÖSUNGSSTRATEGIE	15
5	BAUSTEINSICHT	17
5.1.1	Identity Provider	17
5.1.2	Authorization Server	17
5.1.3	Policy Decision Point	18
5.1.4	Policy Administration Point	18
5.1.5	Policy Repository.....	19
5.1.6	Offene Fragen	20
6	LAUFZEITSICHT	20
6.1	AUTHENTISIERUNG UND AUTORISIERUNG	20
7	VERTEILUNGSSICHT	21
8	QUERSCHNITT KONZEPTE.....	21
9	ARCHITEKTURENTSCHEIDE	21
10	QUALITÄTSANFORDERUNGEN.....	21
10.1	QUALITÄTSBAUM	21
10.2	QUALITÄTSSZENARIEN	21
10.3	RISIKEN UND TECHNISCHE SCHULDEN	21
11	GLOSSAR	22
12	ANHANG	23
12.1	FIKTIVES BEISPIEL FÜR STATISTISCHE ANALYSE.....	23
12.1.1	Ablauf.....	23
12.1.2	Artefakte	23
12.1.3	Policy (Zustimmung)	23
12.1.4	XACML Request.....	24
12.1.5	XACML Response.....	25
12.1.6	OAuth Autorisation Token	25

1 Einführung und Ziele

1.1 Aufgabenstellung

Im Rahmen des Programm DigiSanté soll eine nationale Service Infrastruktur für den Datenraum Gesundheit aufgebaut werden. Die nationale Infrastruktur soll die Services bereitstellen, welche für den Betrieb des Datenraum Gesundheit benötigt werden und nicht von den Teilnehmern selbst bereitgestellt werden können.

Das Identity und Access Management (IAM) zur Authentisierung der Benutzer und zur Autorisierung der Zugriffe durch die Benutzer auf die Daten von Patientinnen und Patienten ist ein integraler Bestandteil des Datenraums Gesundheit und soll als zentraler Dienst bereitgestellt werden.

Dieses Dokument soll die grundsätzlichen Verfahren und die zugrundeliegenden Standards für die Umsetzung der Authentisierung von Benutzern und die Autorisierung von Zugriffen durch die Benutzer beschreiben.

Dieses Dokument soll insbesondere den Zusammenhang der Autorisierung der Zugriffe mit der Einwilligung von Patientinnen und Patienten und die daraus abgeleiteten Anforderungen an die Authentisierung und Autorisierung (Consent Enforcement) klären.

API werden von den Domänen im Datenraum bereitgestellt und müssen den Zugriffsregeln und die Zustimmung von Patientinnen und Patienten durchsetzen. Die Implementierung der Zugriffsrechte und der Zustimmungen soll durch die Bereitstellung von Diensten der nationalen Service Infrastruktur vereinheitlicht und vereinfacht werden, um Datenschutz und Datensicherheit im Datenraum zu gewährleisten.

1.2 Abgrenzung

Stand Dezember 2024 sind die juristischen Rahmenbedingungen für die Zustimmung von Patientinnen und Patienten noch nicht festgelegt. Dieses Dokument beschreibt daher eine generische Lösung auf der Basis des XACML Frameworks, welches auf alle gängigen Anforderungen angepasst werden kann. Die Optionen von Patientinnen und Patienten werden zu einem späteren Zeitpunkt durch Auswahl der Policy Templates und der daraus abgeleiteten Attribute der Nachrichten in einer separaten Spezifikation erstellt.

1.3 Qualitätsziele

Ziel	Beschreibung	Anmerkungen
Verfügbarkeit	Das IAM des Datenraums soll für einen 7*24 Stunden Betrieb ausgelegt sein.	
Sicherheit	Das IAM des Datenraums soll die Anforderungen an Datenschutz- und Sicherheit zur Bearbeitung von Personendaten und besonders schützenswerte Personendaten erfüllen.	
Zero Trust Architektur	Das IAM soll eine Zero Trust Architektur im des Datenraum Gesundheit gemäss «NIST Special Publication 800-207» umsetzen.	

Drittsysteme	Das IAM soll etablierte Services zur Authentisierung von Drittanbietern (Hin, SwissSign, etc.) integrieren.	
Standards	Das IAM soll auf international etablierten Standards aufbauen.	
IAM API	Das IAM soll ein möglichst einfaches API haben und möglichst geringe Anforderungen an die Integration der Systeme des Datenraums stellen.	

1.4 Stakeholder

Stakeholder	Anmerkungen
BAG Architektur	Architekturboard des BAG.
Programm DigiSanté	Programm zur Förderung der Digitalisierung im Gesundheitswesen.
AG Datenraum	Arbeitsgruppe für die Architektur des Datenraum Gesundheit des DigiSanté Programms.
Anbieter von Diensten	Alle potenziellen Anbieter von Daten und Diensten im zukünftigen Datenraum Gesundheit.
Nutzer des Datenraums	Alle potenziellen Nutzer von Daten und Diensten im zukünftigen Datenraum Gesundheit bzw. die Hersteller der Primärsystem und Apps für Patientinnen und Patienten.

1.5 Exemplarische Anwendungsfälle

1.5.1 Informationsaustausch im Behandlungskontext

Eine Patientin sucht mit Beschwerden eine Gesundheitsfachperson in einer ambulanten Praxis auf. Vor der Behandlung hat die Gesundheitsfachperson die Krankengeschichte aus dem EPD der Patientin geladen und gesichtet.

Während der Anamnese teilt die Patientin der Gesundheitsfachperson mit, dass sie aktuell wegen anderer Beschwerden noch in einer anderen Institution behandelt wird.

Die ambulante Praxis und die andere Institution sind an den Datenraum Gesundheit angeschlossen, über den sie Daten austauschen können. Die andere Institution stellt die Informationen in einem Austauschformat über Schnittstellen im Datenraum zur Verfügung.

Dabei wird angenommen, dass die Informationen nicht oder noch nicht im EPD der Patientin abgelegt sind, z.B. weil die Informationen noch nicht finalisiert oder nicht Teil der Krankengeschichte sind.

Beispiele sind:

- Pflegeplan mit aktuellen Einträgen des Pflegepersonals;
- Andere aktuelle Behandlungsdaten.

Die Gesundheitsfachperson in der ambulanten Praxis nutzt den Datenraum zur Abfrage der Informationen (Austauschformate) aus der anderen Institution während der Anamnese in Echtzeit.

Das Primärsystem der Gesundheitsfachperson hat die interoperablen Schnittstellen des Datenraums implementiert. Das Primärsystem kann die maschinenlesbaren Austauschformate lesen, auf den Benutzeroberflächen anzeigen und kann sich mit den vorgängig aus dem Self-Service Portal übernommenen URL und Parametern gemäss den Geschäftsbedingungen mit dem API verbinden.

1.5.1.1 Technischer Ablauf

Das Primärsystem nutzt den ID Token, welcher der Identity Provider zur Authentisierung (AuthN) des Benutzers ausgestellt hat, zusammen mit weiteren fachlichen und administrativen Daten zur Abfrage eines Autorisierungstoken, der für die Abfragen im Datenraum genutzt werden muss. Das Primärsystem sendet dazu eine Anfrage an den Authorization Server des Datenraums.

Der Authorization Server validiert die Daten der Anfrage und nutzt die Daten, um die für die Durchsetzung der Zugriffsrechte und Protokollierung benötigten Attribute¹ (z.B. aus Registern) zu ermitteln. Schlägt die Validierung fehl, so antwortet der Authorization Server mit einer Fehlermeldung.

Der Authorization Server stellt einen Autorisierungstoken (AuthZ) mit den benötigten Attributen aus, welche für die Durchsetzung der Zugriffsrechte und die Protokollierung benötigt werden und signiert den Token. Das Primärsystem nutzt den Autorisierungstoken zusammen mit den Abfrageparametern (fachlich und administrativ) zum Aufruf des API.

Das API validiert den Token auf Gültigkeit und prüft, ob der Token den Aufruf des API autorisiert. Das API prüft dazu die digitale Signatur und die Zeitangaben im Token und validiert die Parameter im AuthZ Token. Schlägt die Validierung fehl, antwortet das API mit einer Fehlermeldung.

Das API führt die fachliche Anfrage des Primärsystems aus und bereitet die resultierenden Daten im Austauschformat auf. Das API sendet für jeden Datensatz der Ergebnismenge eine Anfrage an den Policy Decision Point (PDP) mit den Attributen, welche vom Policy Decision Point (PDP) zur Auswertung der Zugriffsrechte benötigt² werden.

Der Policy Decision Point (PDP) wertet die Anfrage mit den hinterlegten Policies (insb. Zustimmung der Patientinnen und Patienten) aus und trifft den Zugriffsentscheid.

Das API setzt den Zugriffsentscheid um. Das API fügt nur die Daten (Austauschformate) in die Ergebnismenge ein, für die ein positiver Zugriffsentscheid getroffen wurde (z.B., weil die Patientin oder der Patient den Zugriff auf das spezifische Austauschformat im Self-Service Portal autorisiert hat).

Das API sendet die resultierenden Ergebnisse an das Primärsystem, welches die Ergebnisse in den Benutzeroberflächen anzeigt.

¹ Idealerweise sind dies alle Attribute welche zu Durchsetzung der Zugriffsrechte und Protokollierung, damit die Daten nicht von allen API aus den Registern gelesen werden müssen.

² Der PDP benötigt alle Attribute, welche die XCAML Policies zur Auswertung benötigen. Das IAM muss - verglichen mit der Reihenfolge der Aufrufe – rückwärts gedacht und spezifiziert werden. Ausgangspunkt sind die Attribute, welche für die Durchsetzung der Zugriffsrechte (insb. die Zustimmung der Patientinnen und Patienten) im PDP benötigt werden. Daraus müssen die benötigten Attribute des Autorisierungstoken abgeleitet werden.

1.5.2 Patientenapps im Behandlungskontext

Eine Patientin sucht mit einer allergischen Reaktion eine Gesundheitsfachperson in einer ambulanten Praxis auf. Vor der Behandlung hat die Gesundheitsfachperson die Krankengeschichte aus dem EPD der Patientin geladen und gesichtet.

Während der Anamnese teilt die Patientin der Gesundheitsfachperson mit, dass sie eine App für ein Tagebuch mit allergischen Symptomen führt.

Die ambulante Praxis und die App sind an den Datenraum Gesundheit angeschlossen und die App stellt die Informationen in einem Austauschformat über Schnittstellen im Datenraum zur Verfügung.

Die Gesundheitsfachperson in der ambulanten Praxis nutzt den Datenraum zur Abfrage der Informationen (Austauschformate) aus dem API der Tagebuch App während der Anamnese in Echtzeit.

Das Primärsystem der Gesundheitsfachperson hat die interoperablen Schnittstellen des Datenraums implementiert. Das Primärsystem kann die maschinenlesbaren Austauschformate lesen, auf den Benutzeroberflächen anzeigen und kann sich mit den vorgängig aus dem Self-Service Portal übernommenen URL und Parametern gemäss den Geschäftsbedingungen mit dem API verbinden.

1.5.2.1 Technischer Ablauf

Der technische Ablauf ist identisch mit dem Ablauf in 1.5.1.1.

1.5.3 Statistische Analyse

Ein Forschungsprojekt möchte Real Life Data für eine statistische Auswertung aus dem Datenraum Gesundheit nutzen.

Das System der Forschungseinrichtung hat die interoperablen Schnittstellen des Datenraums implementiert. Das System kann die Austauschformate lesen und für die statistische Auswertung nutzen. Das System kann sich mit den vorgängig aus dem Self-Service Portal übernommenen URL und Parametern gemäss den Geschäftsbedingungen mit den API im Datenraum verbinden, welche die benötigten Daten in anonymisierter Form liefern können.

1.5.3.1 Technischer Ablauf

Der technische Ablauf ist identisch mit dem Ablauf in 1.5.1.1. Der Kontext unterscheidet sich aber von den o.g. Use Cases, in denen Daten für einzelne Patientinnen und Patienten abgefragt wurden.

Das Forschungsprojekt fragt Real Life Data von Kohorten von mehreren API im Datenraum ab und die Austauschformate sollen von den API anonymisiert werden. Dazu teilt das System der Forschungseinrichtung im AuthZ Request mit, dass die Ergebnisse vom API anonymisiert werden müssen. Der Authorization Server fügt die geforderte Anonymisierung als Attribut zum Autorisierungstoken hinzu.

1.6 Abläufe

1.6.1 Authentisierung von Benutzern

Benutzer authentisieren sich für Zugriffe auf API im Datenraum an einem, im Datenraum zugelassenen Identity Provider mit dem OpenID Connect Authorization Code Flow.

Der OpenID Connect Authorization Code Flow ist ein etablierter internationaler Standard und ist auch in den EPDV spezifiziert. Er wird von den zertifizierten Identity Providern unterstützt (SwissSign, AGOV), bzw. soll zukünftig unterstützt werden.

Benutzer im Datenraum welche sich mit dem OpenID Connect Authorization Code Flow authentisiert haben, können daher auch auf das EPD zugreifen.

Dieses Konzept referenziert den folgenden Standard:

- OpenID Connect³ – OAuth 2 Implementierung für den Zugriff auf Identitätsdaten bei der Autorisierung.

1.6.2 Autorisierung von Zugriffen

Applikationen autorisieren sich für Zugriffe auf die API des Datenraums am OAuth Authorization Server des Datenraums. Sie senden dazu einen Token Request an den Authorization Server, welcher den Identity Token zusammen mit fachlichen und administrativen Claims enthält.

Bei eingehenden Token Requests prüft der Authorization Server:

- Ob der Token Request vollständig und korrekt ist;
- Ob der Client zum Zugriff auf den Datenraum autorisiert ist;
- Ob der Identity Token von einem vertrauenswürdigen Identity Provider ausgestellt wurde;
- Ob ob der Zeitpunkt des Aufrufs innerhalb des Gültigkeitszeitraum des Identity Token liegt;
- Ob die administrativen und fachlichen Claims berechtigt sind.

Nach erfolgreicher Prüfung stellt der Authorization Server einen Authorization Token (AuthZ) aus, der von der Applikation für Zugriffe genutzt werden soll. Der AuthZ Token enthält mindestens die folgenden Elemente:

- Claims, zu denen der Client berechtigt ist (z.B. ein fachspezifischer Scope oder die URL des API);
- Angaben zur Identität des Benutzers (z.B. Name, GLN, Institution);
- Alle weitere Angaben, welche zur Durchsetzung der Zugriffsrechte von den API benötigt werden.

Der Authorization Server fragt dazu typischerweise Register und Verzeichnisse ab, um die Informationen für den Authorization Token zu ermitteln.

Die Applikation nutzt den Autorisierungstoken bei allen Aufrufen der API des Datenraums.

³ https://openid.net/specs/openid-connect-core-1_0.html

Dieses Konzept referenziert die folgenden Standards:

- JSON Web Token (JWT) Profile for OAuth 2.0 Client Authentication and Authorization Grants⁴ – Spezifikation für die Nutzung von ID Token zur Autorisierung von Zugriffen für OAuth 2.0 bzw. 2.1.
- The OAuth 2.1 Authorization Framework⁵ – Client Credential Flow zur Autorisierung von Zugriffen von Applikationen im Auftrag des Benutzers und Übermittlung von Rollen und Attributen, welche zur Durchsetzung der Zugriffsentscheide benötigt werden.

1.6.3 Durchsetzung der Zugriffsrechte

Die API im Datenraum erhalten mit jedem Aufruf den Autorisierungstoken, welcher vom Authorization Server für den Zugriff durch die Applikation ausgestellt wurde. Das API nutzt die Informationen aus dem Autorisierungstoken zusammen mit den fachlichen und administrativen Daten aus der Anfrage zur Durchsetzung der Zugriffsrechte, insbesondere:

- Administrative Zugriffsrechte auf der Basis der Rolle des Benutzers im Datenraum, ID der Applikation, usw.
- Zugriffsrechte zur Durchsetzung der Zustimmung der Patientinnen und Patienten benötigt werden.

Das API implementiert einen XACML Policy Enforcement Point (PEP) der XACML Referenzarchitektur. Das API extrahiert die Informationen aus dem Authorization Token und den Parametern der Anfrage und erstellt daraus einen XACML Request. Das API sendet den XACML Request an den Policy Decision Point (PDP) im Datenraum, welcher die Zugriffsentscheide gespeicherten Policies (z.B. Einwilligung von Patientinnen bzw. Patienten) trifft. Dabei enthalten die XACML Requests alle Attribute, welche für die Auswertung der Policies durch den Policy Decision Point (PDP) benötigt werden.

Der Policy Decision Point (PDP) trifft die Zugriffsentscheide durch Auswertung der Policies mit den Angaben aus dem XACML Requests. Die Zugriffsentscheide erfolgen auf der Basis von Rollen und Attributen, insbesondere:

- Rollen – Der PDP entscheidet anhand der Rollen (des Benutzers, der Institution, etc.) ob auf die angefragten Daten zugegriffen werden darf;
- Attribute – Der PDP entscheidet anhand der Attribute des Benutzers bzw. der Institution, ob der Zugriff gewährt wird;
- Attribute – Der PDP entscheidet anhand der Attribute der angefragten Daten, ob die Daten in der Antwort gesendet werden dürfen.

Das API setzt den Zugriffsentscheid durch. Das API verweigert oder erlaubt den Zugriff auf das API (Pre AuthZ) und filtert die Ergebnisse so, dass nur die Daten zurückgegeben werden, auf die der Benutzer zugreifen darf (Post AuthZ).

Dieses Konzept referenziert die folgenden Standards:

- XACML 3.0⁶ – Policy Management zur Definition und Einstellung der der Zugriffsrechte durch Patientinnen, Patienten und Administratoren.

⁴ <https://datatracker.ietf.org/doc/html/rfc7523>

⁵ <https://datatracker.ietf.org/doc/html/draft-ietf-oauth-v2-1-11>

⁶ <http://docs.oasis-open.org/xacml/3.0/xacml-3.0-core-spec-os-en.html>

- XACML 3.0 – Policy Enforcement zur Durchsetzung der Zugriffsrechte in den API des Datenraum Gesundheit mit dem JSON Profile⁷.

1.6.4 Consent Management

Patientinnen und Patienten können ihre Zustimmung zum Austausch der über sie erfassten Informationen im Datenraum über das Self-Service Portal steuern. Das Self-Service Portal implementiert dazu einen Policy Administration Point (PAP) der XACML Referenzarchitektur.

Die Zustimmung kann auf verschiedenen Ebenen⁸ erfolgen, wie z.B.:

- Generelle Zustimmung zur Nutzung der Daten⁹;
- Generelle Nutzung einzelner Datensätze auf der Ebene der Austauschformate;
- Nutzung einzelner Datensätze (Austauschformate) durch ausgewählte Institutionen;
- Nutzung einzelner Datensätze (Austauschformate) für ausgewählte Zwecke.

Die möglichen Ebenen der Zustimmungen werden vorab unter Berücksichtigung der Patientenrechte, der User Experience und der Komplexität der technischen Umsetzung von der Governance Group des Datenraums festgelegt.

Sobald festgelegt, werden die Ebenen der Zustimmung im Consent Management über Rollen und Attribute der Benutzer und Attribute der Datensätze modelliert, wie z.B.:

- Rolle des Benutzers;
- Institution und Fachgebiete;
- Verwendungszweck der Daten;
- Eigenschaften der abgefragten Daten.

Patientinnen und Patienten können entweder initiativ oder auf Anfrage die Zustimmung zur Nutzung der Daten im Self-Service Portal geben. Die Benutzeroberflächen des Consent Management unterstützen dazu die Auswahl bzw. die Eingabe der benötigten Attribute. Darüber hinaus können Patientinnen und Patienten die Zustimmung zeitlich beschränken und eine Anonymisierung bzw. Pseudonymisierung festlegen.

Das Self-Service Portal implementiert einen Policy Administration Point (PAP). Es erstellt für jede Zustimmung ein XACML Policy Objekt und speichert es in einen XACML Policy Repository (siehe 3.4).

Darüber hinaus unterstützt das Self-Service Portal weitere Funktionen zum Management der Zustimmung von Patientinnen und Patienten, insbesondere:

- Abfrage und Anzeige der Zustimmungen (Policies);
- Bearbeiten von Zustimmungen (Policies);
- Informationen zu den verschiedenen Optionen der Zustimmung;
- Anzeige von Anfragen zur Erteilung der Zustimmung;

⁷ <https://docs.oasis-open.org/xacml/xacml-json-http/v1.1/xacml-json-http-v1.1.html>

⁸ Die im Datenraum genutzten Ebenen der Zustimmung wurden zum Zeitpunkt der Erstellung dieses Dokuments noch nicht festgelegt. Entsprechend wurden in diesem Dokument Annahmen getroffen.

⁹ Stand 2024 ist die generelle Zustimmung z.B. im Europäischen Datenraum die einzige Option für Patientinnen und Patienten.

- Notifikation bei neuen Anfragen.

Anmerkung:

- Policies sind maschinenlesbare Versionen der Zustimmungen im XACML Format. Das XACML Standard Framework unterstützt viele Funktionen zur Konfiguration der Zustimmungen in den Policies. Für die Nutzung im Datenraum müssen die benötigten Funktionen ausgewählt werden, welche für die Abbildung der Optionen benötigt werden (Profilierung).

Dieses Konzept referenziert die folgenden Standards:

- XACML 3.0 – Policy Management zur Definition und Einstellung der der Zugriffsrechte durch Patientinnen, Patienten und Administratoren.

2 Randbedingungen

Stand November 2024 sind die juristischen Rahmenbedingungen für die Authentisierung und Autorisierung, sowie der Granularität der Einwilligung der Patientinnen und Patienten zur Steuerung der Zugriffe, noch nicht festgelegt.

Dieses Konzept nutzt daher Annahmen über die Authentisierung und Autorisierung, sowie der Granularität der Zugriffsrechte, insbesondere:

- Der Datenraum Gesundheit implementiert das Zero Trust Prinzip gemäss «NIST Special Publication 800-207».
- Der Datenraum Gesundheit nutzt offene und international etablierte Standards zur Authentisierung, Autorisierung und zum Policy Enforcement.
- Der Datenraum Gesundheit setzt die Zugriffsrechte auf der Basis von Rollen (z.B. Gesundheitsfachperson, Assistent, Forschende) durch.
- Der Datenraum Gesundheit setzt die Einwilligung der Patientinnen und Patienten zum Datenaustausch durch. Die Durchsetzung nutzt Eigenschaften der Daten (Metadaten, z.B. Dokumententyp) für welche die Patientinnen und Patienten in die Nutzung (ggf. für einen Zweck, z.B. bestimmte Forschungsprojekte) der Daten eingewilligt haben.
- Der Datenraum Gesundheit implementiert dazu eine auf Rollen und Attribute basierte Zugriffsteuerung.

Dieses Konzept referenziert die folgenden Standards:

- OpenID Connect¹⁰ – OAuth 2 Implementierung für den Zugriff auf Identitätsdaten bei der Autorisierung.
- OAuth 2.1¹¹ – Authorization Code Flow zur Autorisierung von Zugriffen von Applikationen im Auftrag des Benutzers und Übermittlung von Rollen und Attributen, welche zur Durchsetzung der Zugriffsentscheide benötigt werden.
- RFC 7325 JSON Web Token (JWT) Profile for OAuth 2.0 Client Authentication and Authorization Grants¹² – Kommunikation von Identity Token mit dem OAuth Protokoll.
- XACML 3.0¹³ – Policy Management zur Definition und Einstellung der der Zugriffsrechte durch Patientinnen, Patienten und Administratoren.

¹⁰ https://openid.net/specs/openid-connect-core-1_0.html

¹¹ <https://datatracker.ietf.org/doc/html/draft-ietf-oauth-v2-1-11>

¹² <https://datatracker.ietf.org/doc/html/rfc7523>

¹³ <http://docs.oasis-open.org/xacml/3.0/xacml-3.0-core-spec-os-en.html>

- XACML 3.0 – Policy Enforcement zur Durchsetzung der Zugriffsrechte in den API des Datenraum Gesundheit mit dem JSON Profile¹⁴.

3 Kontextabgrenzung

3.1 Fachlicher Kontext

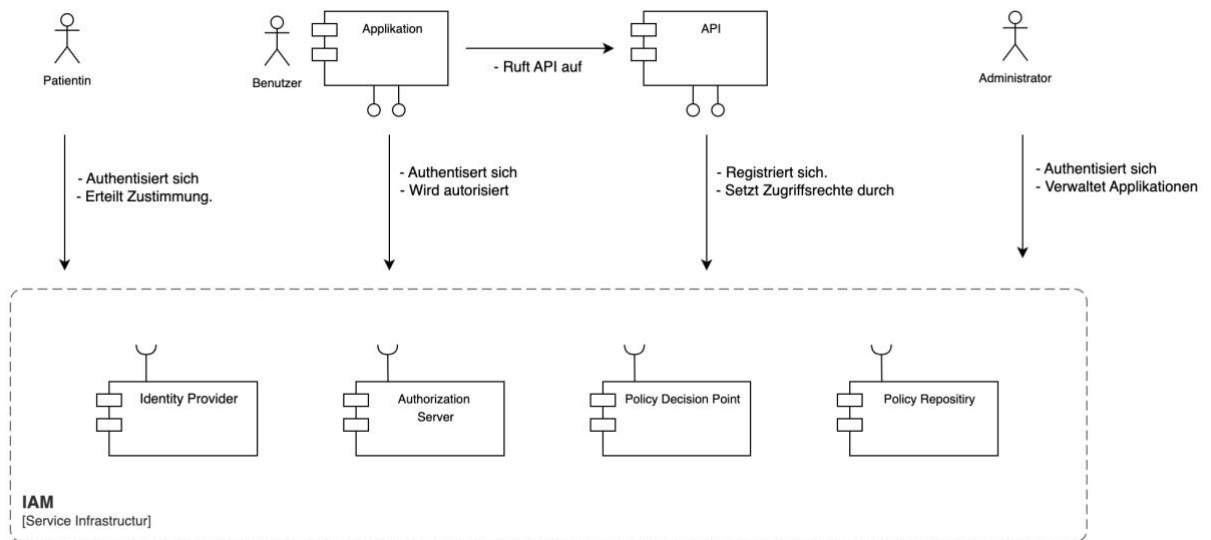


Abbildung 1: Kontextdiagramm des IAM im Datenraum

Im Rahmen des Programm DigiSanté soll eine nationale Service Infrastruktur für den Datenraum Gesundheit aufgebaut werden. Die nationale Infrastruktur soll die Services bereitstellen, welche für den Betrieb des Datenraum Gesundheit benötigt werden und nicht von den Teilnehmern selbst bereitgestellt werden können.

An den Datenraum angeschlossene Systeme sollen zukünftig den Datenraum für den Domänenübergreifenden Austausch von Gesundheitsdaten nutzen. Systeme im Datenraum sind insbesondere:

- Krankenhausinformationssysteme von Spitälern und Kliniken;
- Praxisinformationssysteme von niedergelassenen Ärztinnen und Ärzten;
- Informationssysteme von Heimen, Geburtshäusern und Pflegeeinrichtungen;
- Zentren für radiologische Untersuchungen und Labore;
- Gesundheitsapps für Patientinnen und Patienten;
- Private oder öffentliche Forschungseinrichtungen;
- Bundesamt für Gesundheit und Bundesamt für Statistik.

Die Service Infrastruktur des Datenraums besteht aus allen Diensten, welche zu einem sicheren Betrieb des Datenraum Gesundheit in der Schweiz benötigt werden. Sie sollen von

¹⁴ <https://docs.oasis-open.org/xacml/xacml-json-http/v1.1/xacml-json-http-v1.1.html>

allen Systemen genutzt werden können, welche sich an den Datenraum Gesundheit angeschlossen haben.

Das IAM nimmt eine zentrale Rolle in der Service Infrastruktur ein. Das IAM steuert insbesondere:

- Die Authentisierung von natürlichen Personen, welche auf Daten im Datenraum zugreifen;
- Die Authentisierung der Applikationen, mit denen die Person auf Daten im Datenraum zugreifen;
- Attribut- und Rollenbasierte Autorisierung der Zugriffe durch die Personen;
- Durchsetzung der durch Patientinnen und Patienten erfassten Einwilligung;
- Bearbeitung der Einwilligung durch Patientinnen und Patienten.

3.2 Technischer Kontext

3.3 Authentisierung und Autorisierung

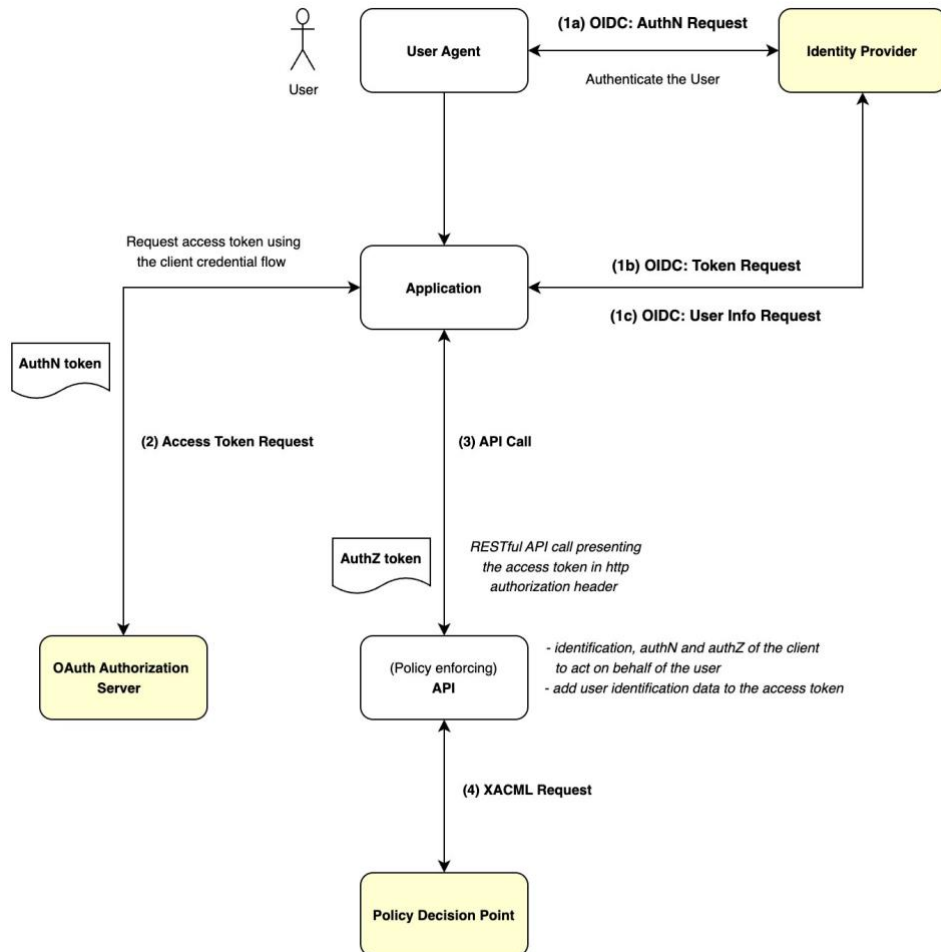


Abbildung 2: Skizze der Abläufe zur Authentisierung und Autorisierung im Datenraum.

Schritt Nr.	Beschreibung
Schritt 1	Ein Benutzer authentisiert sich an einem anerkannten Identity Provider mit einem Verfahren zur starken Authentisierung mit dem User Agent (z.B. Browser, UI des Primärsystems, Mobile Device, usw.) seiner Applikation.
	Bei erfolgreicher Authentisierung sendet der Identity Provider einen Identity Token (AuthN) an die Applikation des Benutzers, bzw. an den User Agent, welcher den Identity Token an die Applikation weiterleitet.
Schritt 2 und 3	Die Applikation nutzt den Identity Token (AuthN) zusammen mit den anderen fachlichen oder administrativen Claims zur Abfrage eines Autorisierungstoken vom Authorization Server.
	Der Authorization Server:

	• Identifiziert die Applikation anhand der Request Daten (Client ID, Client Secret, TLS Zertifikat, usw.). • Verifiziert, ob der Identity Token gültig ist und von einem anerkannten Identity Provider ausgestellt wurde. • Verifiziert, ob die Applikation im Namen des authentisierten Benutzers auf die Services zugreifen darf (User Consent, Policy). • Fragt ggf. Register ab, um die für die Durchsetzung der Zugriffsrechte durch die API benötigten Attribute zu ermitteln. • Erstellt einen Autorisierungstoken (AuthZ) mit allen Informationen, welche für die Durchsetzung der Zugriffsrechte in den API benötigt werden. • Signiert den Autorisierungstoken und sendet ihn mit der Antwort an die Applikation des Benutzers.
Schritt 4	Die Applikation des Benutzers sendet mit jeder Anfrage den Autorisierungstoken im http Header der RESTful Transaktion zum Aufruf des API.
	Das API nutzt die Informationen aus dem Autorisierungstoken, die Daten des Aufrufs und den Attributen der abgefragten Daten und setzt die Zugriffsrechte wie folgt durch: • Pre AuthZ – Entscheidet, ob der Autorisierungstoken zum Aufruf des API berechtigt. • Post AuthZ – Entscheidet, ob die angefragten Daten zurückgegeben werden dürfen. Das API nutzt dazu einen Service, der einen XACML Policy Decision Point (PDP) implementiert und die Zugriffrechte auswertet.

3.4 Consent Enforcement

Services im Datenraum müssen bei jedem Zugriff auf Personendaten und besonders schützenswerte Personendaten die Zustimmung der betroffenen Person durchsetzen. Die Services müssen dazu einen Policy Enforcement Point (PEP) der XACML Referenzarchitektur implementieren.

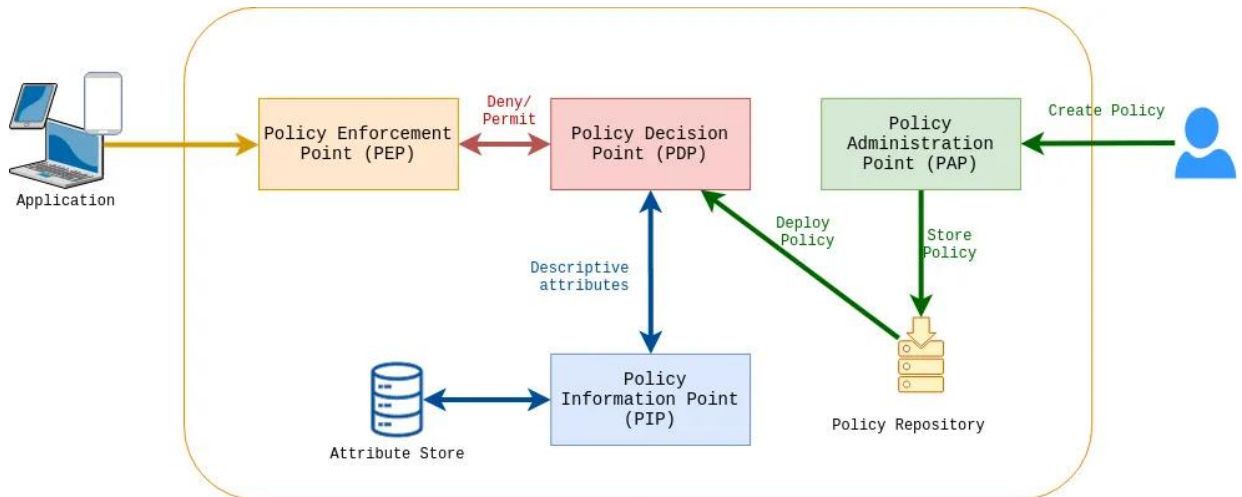


Abbildung 3: XACML Referenzarchitektur

4 Lösungsstrategie

Herausforderung	Strategie
RESTful API	Im Dokument wird angenommen, dass im Datenraum RESTful API für die Kommunikation genutzt werden.
Authentisierung	Der Datenraum implementiert keinen neuen Identity Provider. Die Service Infrastruktur ist so gestaltet, dass digitale Identitäten von den etablierten und anerkannten Identity Provider der Schweiz (z.B. HIN, SwissSign, Trust ID) akzeptiert werden ¹⁵ .
Autorisierung	Der Datenraum implementiert eine Autorisierung von API-Zugriffen mit dem Client Credential Flow des OAuth 2.1 Standards mit den Erweiterungen aus dem RFC 7523 zur Kommunikation von Identity Token der authentisierten Benutzer.
Consent Enforcement	Der Datenraum implementiert ein Consent Enforcement nach dem XACML 3.0 Standard (siehe 3.4) ¹⁶ .

¹⁵ Ggf. wird temporär ein IDP zu Testzwecken bis zum Go Live implementiert.

¹⁶ XACML wird bereits im EPD für die Steuerung der Zugriffsrechte eingesetzt. In Cloud Umgebungen werden aktuell auch andere Ansätze verfolgt, welche aber bisher nicht die gleiche Verbreitung wie XACML erreicht haben.

Zugriffsentscheide	Im Dokument wird angenommen, dass die Zugriffsrechte auf der Ebene der Austauschformate und deren Dokumenttypen (z.B. Medikationskarte, Impfausweis) durchgesetzt werden. Patientinnen und Patienten sollen z.B. ihre Medikationskarten aus dem EMED Austauschformat für Benutzer, Institutionen, Forschungsprojekte, etc. freigeben können, auf Wunsch anonymisiert.

5 Bausteinsicht

5.1.1 Identity Provider

5.1.1.1 Zweck und Verantwortung

Identity Provider bestätigen die elektronischen Identitäten von natürlichen Personen mit einem Authentisierungsverfahren, welche die Anforderungen für den Datenraum erfüllen. Sie nutzen dazu Identifikationsverfahren und Authentisierungsmittel, welche die Identität eines Benutzers bis zum geforderten Grad bestätigen.

5.1.1.2 Schnittstellen

Identity Provider im Datenraum sollen die Schnittstellen des Authorization Code Flow des Open ID Connect Standard¹⁷ implementieren.

5.1.1.3 Qualitäts- und Leistungsanforderungen

Anforderung	Erläuterung
Verfügbarkeit	Identity Provider sollen 7*24 Stunden verfügbar sein.
Last	Identity Provider sollen die erwartete Last ¹⁸ im Datenraum ohne nennenswerte Einschränkungen verarbeiten können.
Qualität	Identity Provider sollen die Anforderungen des Datenraums für elektronischen Identitäten von natürlichen Personen erfüllen, insbesondere: • 2 Faktor Authentifikation; • sichere Identifikation der Benutzer; • sichere Bearbeitung der Daten.

5.1.2 Authorization Server

5.1.2.1 Zweck und Verantwortung

Der Authorization Server stellt Autorisierungstoken aus, mit dem der Zugriff auf die API autorisiert wird und die Informationen zur Durchsetzung der Zugriffsrechte und der Zustimmungen von Patientinnen und Patienten. Er verifiziert dazu den Identity Token und die Claims der Applikation und fragt ggf. Register nach weiteren benötigten Daten ab.

5.1.2.2 Schnittstellen

¹⁷ https://openid.net/specs/openid-connect-core-1_0.html#CodeFlowAuth

¹⁸ Aktuell fehlen noch detaillierte Abschätzungen der zeitlichen Entwicklung der erwarteten Last.

Authorization Server im Datenraum sollen die Schnittstellen des Client Credential Flow des OAuth 2.0 bzw. 2.1 Standards¹⁹ mit den Erweiterungen aus RFC 7523²⁰ implementieren.

5.1.2.3 Qualitäts- und Leistungsanforderungen

Anforderung	Erläuterung
Verfügbarkeit	Der Authorization Server soll 7*24 Stunden verfügbar sein.
Last	Der Authorization Server soll die erwartete Last ²¹ im Datenraum ohne nennenswerte Einschränkungen verarbeiten können.

5.1.3 Policy Decision Point

5.1.3.1 Zweck und Verantwortung

Der Policy Decision Point empfängt XACML Requests von den API, wertet die Einstellungen der Zugriffsrechte (XACML Policies) mit den im Request übermittelten Attributen aus und antwortet mit einer Zugriffsentscheidung, welche von den API durchgesetzt werden soll.

5.1.3.2 Schnittstellen

Policy Decision Points (PDP) im Datenraum sollen die Schnittstelle des internationalen Standards «JSON Profile of XACML 3.0 Version 1.1»²² implementieren

5.1.3.3 Qualitäts- und Leistungsanforderungen

Anforderung	Erläuterung
Verfügbarkeit	Der Policy Decision Point soll 7*24 Stunden verfügbar sein.
Last	Der Policy Decision Point soll die erwartete Last ²³ im Datenraum ohne nennenswerte Einschränkungen verarbeiten können.

5.1.4 Policy Administration Point

5.1.4.1 Zweck und Verantwortung

Der Policy Administration Point ist eine Komponente des Self-Service Portals, mit der Administratoren des Datenraums die Zugriffsrechte gemäss den Vorgaben des Datenraums konfigurieren und Patientinnen und Patienten ihre Zustimmung zum Datenaustausch geben können.

¹⁹ <https://datatracker.ietf.org/doc/html/draft-ietf-oauth-v2-1-11>

²⁰ <https://datatracker.ietf.org/doc/html/rfc7523>

²¹ Aktuell fehlen noch detaillierte Abschätzungen der zeitlichen Entwicklung der erwarteten Last.

²² <https://docs.oasis-open.org/xacml/xacml-json-http/v1.1/xacml-json-http-v1.1.html>

²³ Aktuell fehlen noch detaillierte Abschätzungen der zeitlichen Entwicklung der erwarteten Last.

5.1.4.2 Schnittstellen

Der Policy Administration Point bzw. das Self-Service Portal implementiert RESTful Schnittstellen zur Abfrage und Bearbeitung von Policies im Format des internationalen Standards «eXtensible Access Control Markup Language (XACML) Version 3.0»²⁴.

Anmerkung:

- Der XACML Standard unterstützt aktuell nur Policies im XACML Format. Eine Erweiterung um ein JSON Format ist aktuell in Diskussion. Stand Dezember 2024 gibt es aber inoffizielle, nicht standardisierte JSON Formate²⁵.
- Alternativ können Policies auch im ODRL²⁶ Format übertragen und zur Speicherung und Auswertung in XACML Policies konvertiert werden.

5.1.4.3 Qualitäts- und Leistungsanforderungen

Anforderung	Erläuterung
Verfügbarkeit	Policy Administration Points sollen 7*10 Stunden verfügbar sein.
Last	Policy Administration Points müssen die erwartete Last ²⁷ im Datenraum ohne nennenswerte Einschränkungen verarbeiten können.
User Experience	Die Benutzeroberflächen des Policy Administration Points im Self-Service Portal sollen eine hohe Benutzerfreundlichkeit ausweisen, insbesondere die Benutzeroberflächen in denen die Patientinnen und Patienten ihre Zustimmung erteilen.

5.1.5 Policy Repository

5.1.5.1 Zweck und Verantwortung

Das Policy Repository speichert und verwaltet die administrativen Zugriffsrechte und die Zustimmung zum Datenaustausch von Patientinnen und Patienten im maschinenlesbaren XACML Format.

5.1.5.2 Schnittstellen

Das Policy Repository implementiert RESTful Schnittstellen zur Abfrage und Bearbeitung von Policies im Format des internationalen Standards «eXtensible Access Control Markup Language (XACML) Version 3.0»²⁸.

5.1.5.3 Qualitäts- und Leistungsanforderungen

Anforderung	Erläuterung
Verfügbarkeit	Das Policy Repository soll 7*24 Stunden verfügbar sein.

²⁴ <https://docs.oasis-open.org/xacml/3.0/xacml-3.0-core-spec-os-en.html>

²⁵ <https://github.com/authzforce/xacml-json-model>

²⁶ <https://www.w3.org/TR/odrl-model/>

²⁷ Aktuell fehlen noch detaillierte Abschätzungen der zeitlichen Entwicklung der erwarteten Last.

²⁸ <https://docs.oasis-open.org/xacml/3.0/xacml-3.0-core-spec-os-en.html>

Last	Identity Provider müssen die erwartete Last ²⁹ im Datenraum ohne nennenswerte Einschränkungen verarbeiten können.

5.1.6 Offene Fragen

Keine.

6 Laufzeitsicht

6.1 Authentisierung und Autorisierung

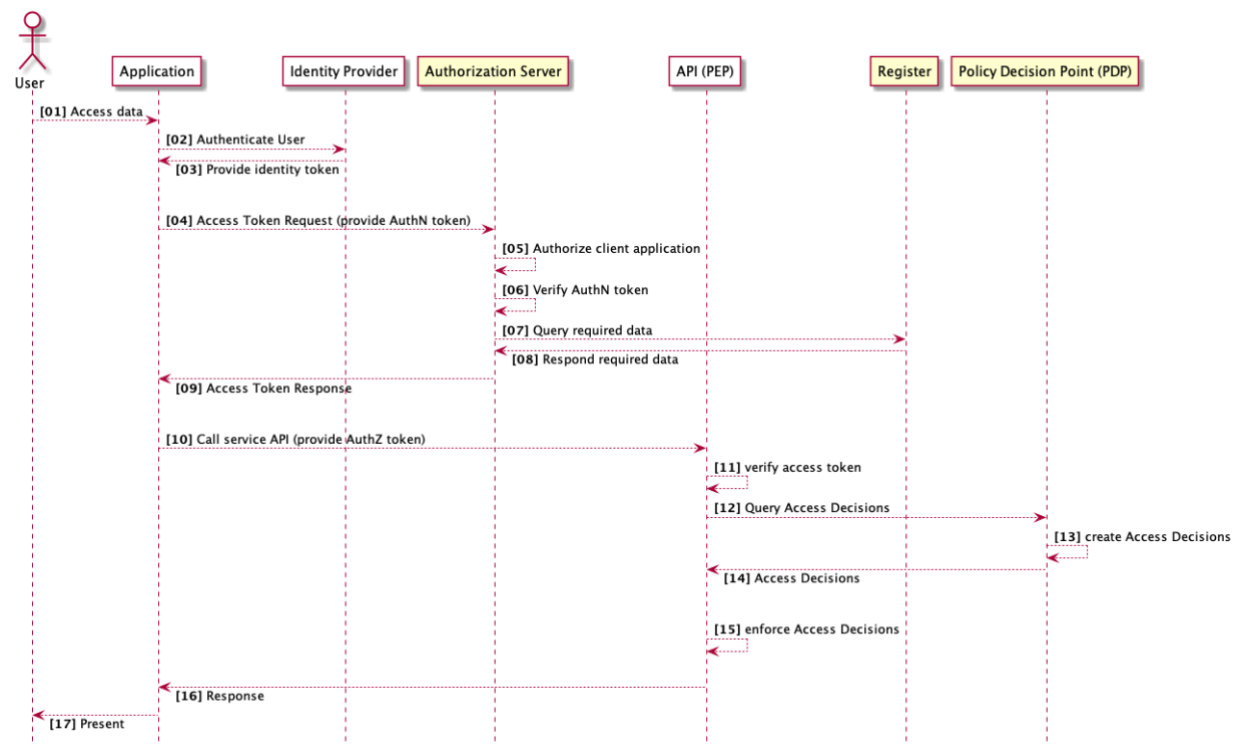


Abbildung 4: Sequenzdiagramm der Prozesse zur Authentisierung und Autorisierung bei Zugriff auf die API im Datenraum.

²⁹ Aktuell fehlen noch detaillierte Abschätzungen der zeitlichen Entwicklung der erwarteten Last.

7 Verteilungssicht

8 Querschnitt Konzepte

Werden im Rahmen der Projektinitialisierung erstellt.

9 Architekturentscheide

Werden im Rahmen der Projektinitialisierung erstellt.

10 Qualitätsanforderungen

10.1 Qualitätsbaum

Wird im Rahmen der Projektinitialisierung erstellt.

10.2 Qualitätsszenarien

Werden im Rahmen der Projektinitialisierung erstellt.

10.3 Risiken und technische Schulden

Werden im Rahmen der Projektinitialisierung erstellt.

11 Glossar

Begriff	
Zero Trust Architektur	Paradigmenwechsel im Design von sicheren IT-Systemen nach Analyse der Sicherheitsvorfälle der Vergangenheit. Wichtigste Kennzeichen einer Zero Trust Architektur ist die konsequente Umsetzung personenbezogener Autorisierung für den Zugriff für alle geschützten Ressourcen, sowie der Einsatz von Intrusion Prevention (IPS) zur Erkennung anormalen bzw. unerwünschten Verhaltens. Die Zero Trust Architektur unterscheidet sich damit von älteren Ansätzen des Perimeterschutzes mit sicheren bzw. unsicheren Zonen, da in der Zero Trust Architektur grundsätzlich keine Zone als sicher eingestuft wird. Die Anforderungen sind in der «NIST Special Publication 800-207» angegeben und müssen z.B. in allen US-Behörden bis Ende 2024 umgesetzt werden.
Cloud Service Provider	Dienstleister für die administrativen Tätigkeiten in der Cloud, welcher die Leistungen im Auftrag des BAG erbringt.
OAuth 2.x	Standard für Web-basierte Protokolle, die eine standardisierte, sichere API-Autorisierung für Desktop-, Web- und Mobile-Anwendungen erlauben.
OpenID Connect	Authentifizierungsschicht auf der Basis von Autorisierungsframework OAuth 2.0.
XACML	Ein XML und JSON-basierter Sprachstandard für maschinenlesbare Sicherheitsrichtlinien (Policies), Zugriffsanforderungen und Zugriffsentschiede für eine auf Rollen- und Attribute basierende Zugriffssteuerung. Mit XACML Policies können administrative Zugriffsanforderungen und auf der Zustimmung von Patientinnen und Patienten abgeleitete Zugriffsanforderungen implementiert werden. Neben dem Sprachstandard definiert XACML eine Referenzarchitektur, die in Fachkreisen etabliert ist.
Pre AuthZ	Autorisierungsentscheid, ob ein API den Aufruf einer Applikation verarbeiten darf.
Post AuthZ	Autorisierungsentscheid, ob ein API einen Datensatz aus der Ergebnismenge einer Anfrage im Response zurückgeben darf.

12 Anhang

12.1 Fiktives Beispiel für Statistische Analyse

12.1.1 Ablauf

Das Bundesamt für Gesundheit (BAG) beauftragt eine Studie zur statistischen Analyse von Medikationsdaten in der Schweiz. Die Studie will dazu Real Life Daten aus dem Datenraum Gesundheit nutzen. Das BAG publiziert Informationen zur Studie und bittet Patientinnen und Patienten um freiwillige Teilnahme.

Das Studienteam veröffentlicht ein Formular zur Zustimmung für Patienten und Patienten im Self-Service Portal des Datenraums Gesundheit. Im Formular wird um Zustimmung zur Abfrage des Austauschformats der Medikationskarte gebeten.

Frau Verena Müller hat die Informationen gelesen und sich entschlossen, ihre Daten für das Projekt freizugeben. Frau Müller meldet sich dazu mit einer 2 Faktor Authentisierung (z.B. AGOV mit E-ID) am Self-Service Portal an, wechselt in das Formular zur Zustimmung zur Studie und erteilt ihre Zustimmung. Das Self-Service Portal speichert die Zustimmung zur Studie als XACML Policy im Policy Repository.

Das Studienteam nutzt das Self-Service Portal zur Abfrage der Medikationskarten der Patientinnen und Patienten aus den Systemen im Datenraum Gesundheit. Sie ermitteln die API im Datenraum, welche die Medikationskarten von Patientinnen und Patienten liefern können und konfigurieren ihren Client für die Abfragen. Der Client fragt einen Autorisierungstoken für die Abfragen am Authorization Server ab und sendet die Abfragen mit dem Autorisierungstoken an die API.

Die API lesen die für die Durchsetzung der Zugriffsrechte benötigten Informationen aus den Parametern der Abfrage und dem Autorisierungstoken. Die API erstellen einen XACML Request und senden den Request an den Policy Decision Point des Datenraums.

Der Policy Decision Point wertet die Anfrage mit den Policies der Zustimmungen aus und antwortet mit dem Zugriffsentscheid, welchen die API durchsetzen. Das API sendet die Ergebnisse in der Antwort an den Client des Studienteams.

12.1.2 Artefakte

12.1.3 Policy (Zustimmung)

Die Policy ist eine maschinenlesbare Version der Zustimmung der Patientinnen bzw. Patienten mit mindestens den folgenden Elementen:

- Formel – Prüfung, ob die Institution im XACML Request das BAG ist?
- Formel – Prüfung, ob das Projekt im XACML Request die Studie ist?
- Formel – Prüfung, ob das angefragte Austauschformat die Medikationskarte ist?

Im Folgenden ist ein Beispiel für eine Policy im JSON Format (nicht normativ) angegeben. Zur besseren Lesbarkeit ist im Beispiel nur die Formel zur Prüfung der Institution angegeben. Alle anderen Formeln sind analog aufgebaut:

```

{
  "policy": {
    "id": "2bb5a93d-b4ec-457e-80cc-821154958613",
    "target": [
      [
        [
          {
            "matchFunc": "string-equal",
            "matchedValue": "BAG",
            "attrDesignator": {
              "category": "subject",
              "attrId": "institution",
              "dataType": "XMLSchema#string",
              "mustBePresent": true
            }
          }
        ]
      ]
    ],
    "...
    "combinerId": "rule-combining-algorithm:deny-unless-permit"
  }
}

```

12.1.4 XACML Request

Der XACML Request wird von den API zur Abfrage der Zugriffsrechte genutzt und enthält mindestens die folgenden Attribute:

- Die AHVN 13 der Patientin Fr. Verena Müller.
- Die ID der Institution BAG.
- Die ID des Austauschformats Medikationskarte.

Das folgende Beispiel (nicht normativ) zeigt einen XACML Request für den Use Case:

```

{
  "Request": {
    "Ssubject": {
      "Attribute": [
        {
          "AttributeId": "institution",
          "Value": "BAG",
          "DataType": "string"
        }
      ]
    }, {
      "Attribute": [
        {
          "AttributeId": "project",
          "Value": "MedStatAnalyse",
          "DataType": "string"
        }
      ]
    },
    "Resource": {
      "Attribute": [
        {
          "AttributeId": "resource-id",
          "Value": "756.XXXX.XXXX.XX",
          "DataType": "string"
        }
      ]
    }, {
  }, {

```



```

        "Attribute": [
            {
                "AttributeId": "resource-type",
                "Value": "MedicationCard",
                "DataType": "string"
            }
        ],
        "Action": {
            "Attribute": [{
                "AttributeId": "action-id",
                "Value": "read",
                "DataType": "string"
            }]
        }
    }
}

```

12.1.5 XACML Response

Der XACML Response enthält den Zugriffsentscheid (Status) mit den möglichen Werten:

- Permit – Wenn der Zugriff auf die Daten autorisiert ist.
- Deny – Wenn der Zugriff auf die nicht Daten ist.
- NotApplicable – Wenn keine Policy gefunden werden kann, mit ein Zugriffsentscheid getroffen werden kann.
- Indeterminate – Wenn Informationen für den Entscheid fehlen.

Das folgende Beispiel (nicht normativ) zeigt einen XACML Response für den Use Case:

```

{
  "Response": [{
    "Decision": "Permit"
    "Status": {
      "StatusCode": {
        "Value": "urn:oasis:names:tc:xacml:1.0:status:ok"
      }
    }
  }]
}

```

12.1.6 OAuth Authorization Token

Der OAuth 2.x Authorization Token wird vom Authorization Server ausgestellt und vom API mit jeder Abfrage nach Personendaten mitgeschickt. Er enthält mindestens die folgenden Attribute:

- Die ID der Institution BAG.
- Die ID des Projekts.
- Die ID des Austauschformats Medikationskarte.

Das folgende Beispiel (nicht normativ) zeigt einen OAuth Authorization Token für den Use Case:

```

{
  "iss": "http://AuthorizationServer.ch",
  "sub": "756.YYYY.YYYY.YY",
  "aud": "http://example.org/api",

```

```

    "exp": 1587294580000,
    "nbf": 1587294460000,
    "iat": 1587294460000,
    "jti": "c5436729-3f26-4dbf-abd3-2790dc7771a",
    "institution": "BAG",
    "project": "MedStatAnalyse",
    "resource-type": "MedStatAnalyse"
}

```

12.1.7 Abfrage der API

Die Abfrage wird vom Client an das API gesendet und enthält mindestens die folgenden Parameter:

- URL des API.
- ID des Austauschformats.

Das folgende Beispiel (nicht normativ) zeigt einen Aufruf des RESTful API mit dem encoded Authorization Token im http Header:

```

GET http://example.org/api/MedicationCardDocument?status=current
HTTP/1.1
Accept: application/fhir+json
traceparent: 00-0af7651916cd43dd8448eb211c80319c-b7ad6b7169203331-00
Authorization: Bearer d2lraTpWZWRpYQ==

```

12.1.8 Identity Token

Der Identity Token wird nach erfolgreicher Authentisierung des Benutzers vom Identity Provider an die Client Applikation des Benutzers abgefragt werden und enthält mindestens die folgenden Parameter:

- IDP ID des Benutzers.
- Die GLN oder die AHVN13 des Benutzers.

Das folgende Beispiel (nicht normativ) zeigt einen Identity Token des Benutzers:

```

{
  "family_name": "Müller",
  "given_name": "Verena",
  "groups": [
    "BAG",
    "Scientific Research"
  ],
  "preferred_username": "müller.verena@bag.ch",
  "sub": "756.YYYY.YYYY.YY"
}

```